Penetration Testing Basic TASK-2

1.List 5 common vulnerabilities that can be found in popular apps like Instagram, Zomato, or Paytm, and briefly describe how each one could impact users if not fixed.

Ans :

1. **Broken Authentication:** Weak login mechanisms or poor session management could allow attackers to access user accounts, potentially stealing personal information or taking control of accounts.

2. **SQL Injection:** Improperly validated database queries could allow attackers to access, modify, or delete sensitive information, such as user profiles or order records.

3. **Cross-Site Scripting (XSS):** Improper handling of user input could allow malicious scripts to run in another user's browser, potentially exposing session information or personal data.

4. **Insecure Data Storage:** Storing passwords, payment details, or personal information without adequate protection could expose sensitive user data if a device or server is compromised.

5. **Broken Access Control:** Incorrect permission checks could allow users to view or modify another person's account details, orders, or transaction information without authorization.

2.Install Nessus Essentials on your Windows or Linux system, create an account, and take a screenshot of the Nessus dashboard after your first successful login.

Ans :

1. Open https://www.tenable.com/products/nessus/nessus-essentials
2. Download the Nessus Essentials installer for Windows or Linux.
3. Run the installer and complete the installation.

4. Open your browser and visit https://localhost:8834/
5. Follow the setup wizard and select Nessus Essentials.
6. Register for an activation code and activate Nessus.
7. Create your administrator account and wait for initialization to finish.
8. Log in to Nessus and open the dashboard.
9. Take a screenshot using Win + Shift + S on Windows or PrtSc on Linux.

**3.Configure Nessus to scan your own laptop or a test virtual machine for vulnerabilities, then generate and save the scan report as a PDF.

Hint: Use the 'Basic Network Scan' template and select your device's IP address as the target.**

Ans :

1. Open Nessus in your browser at https://localhost:8834/.
2. Log in using your administrator account.
3. Click **New Scan**.
4. Select the **Basic Network Scan** template.
5. Enter a name, such as Laptop Vulnerability Scan.
6. In the **Targets** field, enter your own laptop's or test VM's IP address.
7. Save the scan configuration.
8. Click **Launch** to start the scan.
9. Wait until the scan status shows **Completed**.
10. Open the completed scan and review the discovered vulnerabilities and their severity levels.

11. Click **Export** and select **PDF** (or the available PDF report option).
12. Save the report as nessus_vulnerability_report.pdf.

4.Compare Nessus and OpenVAS by listing 3 features or differences between them that would matter if you were scanning a real-world app like Flipkart or Myntra.

Ans :

Feature	**Nessus**	**OpenVAS**
1. Cost and licensing	Nessus Essentials offers free, limited vulnerability scanning; paid Nessus plans provide additional capabilities.	OpenVAS is an open-source vulnerability scanning option, commonly used through Greenbone Community Edition.
2. Vulnerability detection	Provides vulnerability checks, plugin-based detection, and detailed findings for identifying issues in servers and network services.	Uses vulnerability tests to identify security issues in network services, operating systems, and supported applications.
3. Reporting and usability	Offers a user-friendly interface and detailed reports that help security teams prioritize and document findings.	Provides reporting and vulnerability management capabilities, but setup and maintenance may require more technical knowledge.